

Multi-Factor Authentication (MFA) For Public Access | Technology Solution Office (TSO) Business Requirements

1.0. Basic Authentication, MFA, Identity Proofing (Enrollment)

- 1.1. The solution for public access must enable application configuration and integration with a vendor that provides unified identity authentication.
- 1.2. The vendor solution must include user identity storage and management.
- 1.3. The vendor solution should comply with the following assurance levels to avoid authentication, proofing, and federation errors: [NIST.SP.800-63-3 Digital Identity Guidelines Section 5.1](#). When combined with these guidelines, it will refer to Identity Assurance Level (IAL), Authenticator Assurance Level (AAL), and Federation Assurance Level (FAL) as xAL.
 - 1.3.1. To ensure compliance with data security standards, judiciary applications must be classified as Low, Medium, or High based on the security of application's data ([NIST.SP.800-63-3 Digital Identity Guidelines Section 5.1](#)). Please note that the TSO recommends all Judiciary applications are able to meet IAL2 & AAL2 assurance levels.
 - 1.3.2. The vendor solution must support all Judiciary applications categorized as low/medium data security classification. If they're not in compliance for high rated data security compliance applications, they should be on the solution's future roadmap.
- 1.4. The vendor solution should authenticate users based on proof of possession of a key through a cryptographic protocol that retains over the user's logged-in status in (complying with Authenticator Assurance Level AAL2 or AAL3 [NIST.SP.800-63b Section 4.3](#)).
- 1.5. The vendor should support user identity migration.
 - 1.5.1. If the vendor is unable to support user identity migration, then the solution for public access must require users to re-enroll to gain access.
- 1.6. The vendor solution must enable users to authenticate with MFA following AAL guidelines ([NIST.SP.800-63-3](#)).
- 1.7. Users should have the option to opt out of MFA if they are granted a special exception that permits them to bypass MFA during authentication.
- 1.8. The vendor solution must support more than one authentication method, including more than one MFA method for US Courts Users. These methods include:
 - 1.8.1. Biometric authentication & password-less authentication (face recognition, finger printing) (ref: [NIST-800-63-4 newer version](#) Section 5.2)
 - 1.8.2. Push notifications

- 1.8.3. Time-Based One-Time Password (TOTP) Authenticators
- 1.9. The vendor solution must be cloud-based Software as a Service (SAAS).
- 1.10. The vendor solution must be Federal Risk and Authorization Management Program (FedRAMP) certified with FEDRAMP Moderate to High impact level which is equivalent to Department of Defense (DoD) level2 - level4 and 5 ([NIST SP 1800-17b](#) [NIST SP 800-63-3](#)).
- 1.11. The solution must enable a user enrollment process for registering or creating user identities with vendor-based authentication systems while following the general requirements outlined in [NIST.SP.800-63a section 4.2](#), related to user identity proofing, personally identifiable information (PII) data collection, and the disposal of PII information.
 - 1.11.1. Vendor must support Identity Proofing Solution, identity proofing for external users involves verifying the identity of individuals outside of the judiciary, typically when they are accessing judiciary applications. This process ensures that the person claiming an identity is who they say they are.
 - 1.11.2. Vendor solution should support various identity proofing methods.
 - 1.11.2.1. Digital Proofing:
Government-issued IDs: Passport, driver's license, national ID cards.
Secondary IDs: Utility bills, bank statements for additional proof.
Knowledge Based Verification: Questions related to credit history.
Live Agent Verification: Any additional options.
 - 1.11.2.2. In-person Proofing:
In-person identity proofing involves verifying an individual's identity face-to-face, typically by checking government-issued identification documents and, in some cases, capturing biometric data.
 - 1.11.3 Vendor solution should have Identity Proofing for International users, Identity proofing for international users involves verifying the identity of individuals across different countries, each with its own set of regulations, identification systems, and languages considering regulatory constraints (General Data Protection Regulation) of local nations.

2.0. User Management

- 2.1. The solution vendor should provide a system for managing access to resources, focusing on authenticating and authorizing users or entities This ensures that the appropriate individuals have access to the correct resources at the right time and for the right reasons. Included in this management is the prevention of

unauthorized access, administration of user roles and permissions, and monitoring of user activities. Additionally, the context of impersonation or access delegation to other users must be considered.

- 2.2. The solution vendor must offer processes for user identity management and support the following basic features while ensuring that these features are readily accessible on the login page and that users can perform these actions independently without the need for assistance or restricted availability:
 - Forgot username or password
 - User Account Password Reset
 - User Profile Update (e.g., email, phone change)
 - Add or change the authentication method
 - Add or change MFA setup methods
 - Identity Proofing (Verify your Identity)
- 2.3. The solution vendor should offer user identity management with Access Control Levels, including:
 - User account provisioning and de-provisioning for applications.
 - Ensuring that new users gain access immediately after provisioning, while removing access for departing or inactive users immediately after de-provisioning while making sure user's access intact with other active applications.
- 2.4. The solution must perform periodic reauthentication of user sessions upon the possession of a session secret key issued by the verifier at the time of authentication and optionally refreshed during the session. Periodic reauthentication of sessions shall be performed to confirm the continued presence of the subscriber at an authenticated session and that the user has not left their session unattended without logging out. ([NIST.SP.800-63b section 7.2](#)).
- 2.5. The solution must follow the record retention policy described in [NIST.SP.800-63b section 4.1.5](#).

3.0. Performance (Scalable, Available, Logging, Monitoring, Reporting):

- 3.1. The vendor-based solution must be scalable across multiple applications and users within an enterprise environment.
- 3.2. The vendor-based solution must have 99.999% application availability.
- 3.3. The vendor should be able to prove & quantify the application's availability. The vendor-based solution must be compatible with existing enterprise logging mechanisms.
- 3.4. The vendor-based solution should populate the event logs in near real-time for authentication and MFA with the basic attributes to fill in below:
 - Event category (authentication or MFA)
 - Event, date, time

- Event status (success or failure)
- Reason for failure
- User Identity, user trying to login

3.5. The vendor-based solution should offer monitoring and reporting capabilities.

4.0. Support:

The vendor should come up with comprehensive processes to support both end users and application development teams.

- 4.1. Development Support: The chosen vendor solution must provide comprehensive development support, including robust documentation, Software Development Kits (SDKs), and Application Programming Interfaces (APIs) to facilitate seamless integration with various application development enterprise environments. Additionally, the vendor should offer developer-friendly features and resources to streamline the authentication and authorization process during application development.
- 4.2. Application Configuration and Flexibility: It is imperative that the selected vendor solution offers extensive configuration options and flexibility to adapt to our application's unique requirements. This includes customizable authentication workflows, support for various authentication mechanisms (e.g., SAML, OAuth), and the ability to tailor user access policies based on our application's specific security needs. Furthermore, the vendor should allow for easy scalability and accommodate future expansion or modifications to our authentication infrastructure without significant overhead.
 - 4.2.1. Automation/Regression Test Suite support: The vendor should facilitate automation testing capabilities through adaptable application configurations or other means, permitting the bypassing of MFA for designated test user accounts in lower environments.
- 4.3. Frequency of Production and Post-Production Changes: Given the dynamic nature of our enterprise environment, the chosen vendor solution should facilitate smooth integration and accommodate frequent production and post-production changes with minimal disruption. This includes seamless updates to authentication configurations, support for automated deployment pipelines, and robust version control mechanisms to manage changes effectively. Additionally, the vendor should offer comprehensive testing and staging environments to validate modifications before deploying them into production, ensuring high availability and reliability of our authentication services. Production and post-production changes should be implemented near real time.
- 4.4. The vendor should come up with comprehensive processes for post-production support for both end users and application development teams. The following is a structured approach outline:

- 4.4.1. Ticketing System Setup: Implement a centralized ticketing system, such as JIRA Service Desk or Zendesk, to manage and track support requests from end users and development teams efficiently. Configure the ticketing system to categorize requests based on severity, impact, and type of assistance needed.
- 4.4.2. Support Channels Definition: Define clear channels through which end users and development teams can submit support requests. This may include email, a dedicated support portal, or integration with communication platforms like Slack or Microsoft Teams for real-time assistance.
- 4.4.3. Service Level Agreement (SLA) Establishment: Define SLAs outlining the expected response and resolution times for different types of support requests. SLAs should be tailored to prioritize critical issues impacting production systems while also promptly addressing non-urgent inquiries from development teams and provision of escalation Point of Contact (POC) if the SLAs are not met.
- 4.4.4. Tiered Support Structure: Establish a tiered support structure with designated levels of expertise and responsibilities. This may include a frontline support team for initial triage and basic troubleshooting, followed by specialized teams or subject matter experts for more complex issues.
- 4.4.5. Knowledge Base and Documentation: Develop and maintain a comprehensive knowledge base and documentation repository accessible to both end users and development teams. This resource should contain troubleshooting guides, FAQs, best practices, and reference materials to empower users to resolve common issues independently.
- 4.4.6. Escalation Procedures: Define clear escalation procedures for unresolved issues or incidents requiring higher-level intervention. Establish escalation paths within the support team hierarchy and protocols for engaging additional resources or stakeholders, such as software developers or system administrators, when necessary.
- 4.4.7. Continuous Improvement and Feedback Loop: Implement mechanisms for gathering feedback from both end users and development teams to identify areas for improvement in the support process. Conduct regular reviews and retrospectives to analyze support metrics, identify recurring issues, and implement proactive measures to prevent future incidents.
- 4.4.8. The solution must show how and where to get technical assistance, through an online self-service feature, chat sessions, or help desk support (NIST SP 800-63c Section 10.1).

5.0. Training:

- 5.1. The vendor-based solution must provide clearly defined training modules and a comprehensive support structure concerning authentication, MFA methods, and user management.
 - 5.1.1. The training modules should cover all essential aspects of authentication, MFA methods, and user management in a manner that ensures users have a thorough understanding and proficiency in these areas.
 - 5.1.2. The support structure should be capable of addressing all relevant inquiries and issues through documentation, training materials, technical support, continuous update/maintenance cycles, guidance on security practices, and feedback mechanisms as well. (NIST SP 800-63c Section 10.1).

6.0. Security and Standards:

- 6.1. The solution must incorporate security measures to mitigate phishing attacks and minimize the risk of man in the middle (MitM) attacks (NIST.SP.800-63b section 4.1.2).
- 6.2. The solution should follow general authenticator requirements mentioned in, NIST-800-63-4 newer version Section 5.2. Adherence to NIST standards IAL & AAL levels makes sure protection against impersonation, fraud, or other significantly harmful damages.
- 6.3. The solution vendor must be compliant with [NIST SP 800-53](#) 'Security and Privacy Controls for Information Systems and Organizations' Will be validated on all privileges mentioned in the document.
- 6.4. The vendor-based authentication solution should be compatible with Fast Identity Online (FIDO) ([NIST joins FIDO Alliance](#)).
 - 6.4.1. Compatibility with FIDO passcode key services during enrollment:
 - During authentication, user should unlock the FIDO authenticator using the same method as at enrollment time.
- 6.5. The proposed solution should comply with [FIPS 140-3](#). Applications operated by government agencies at AAL1, AAL2 SHALL be validated to meet the requirements of FIPS 140 Level 1. ([NIST 800-63b, section 4.2.2](#))
- 6.6. The solution should ensure adherence to the enterprise's 'Zero-Trust Policy' for applications, servers, and AI's ([NIST SP 800-207](#)). [ITSO Cybersecurity strategy page 4](#).
 - All incoming and outgoing connections should be managed by central firewall restrictions and port settings.